

Enterprise Information Security Policy

Corporate Governance Policy Manual | Document Ref: **POL-SEC-2024-v3.2** | Version 3.4

Section 1.1: Scope and Multi-Factor Access Control

This policy governs all corporate systems, vendors, and third-party SaaS applications processing company data. Multi-factor authentication (MFA) is strictly required across all administrative, API, and end-user access points. Passwords must adhere to NIST 800-63B standards.

Section 2.1: Mandatory Encryption Standards

All sensitive customer and company data must be encrypted at rest using industry-standard AES-256 cipher suites. All data in transit across public or untrusted networks must be encrypted using Transport Layer Security (TLS) protocol version 1.3 (or minimum TLS 1.2 with perfect forward secrecy). Unencrypted transmissions are strictly prohibited.

Section 3.2: Security Incident Notification Timelines

In the event of a confirmed or suspected Security Incident, unauthorized access, or Data Breach, any contracted service provider or vendor must notify the Company Information Security Team in writing within twenty-four (24) hours of initial discovery. The notification must include root cause, impacted data records, and immediate mitigations.

Section 4.1: Vulnerability Remediation SLAs

Vendors must remediate critical vulnerabilities (CVSS score ≥ 9.0) within seven (7) calendar days of public disclosure. High severity vulnerabilities must be remediated within thirty (30) calendar days. Ordinary release deferrals for critical patches are strictly prohibited.

Section 5.3: Threat Monitoring and Log Retention

All audit logs, administrative access records, and security telemetry must be preserved for a minimum period of three hundred sixty-five (365) days in immutable, tamper-resistant storage.